Nama : Nadjlah Cahya Nerik Fadilah **NIM : 3224001** **Sistem Informasi**

Eksploitasi Apache Struts 2 (CVE-2017-5638) yang Belum Dipatch pada Insiden Kebocoran Data Equifax 2017

Kategori OWASP: *A06 — Vulnerable and Outdated Components*

Deskripsi Kerentanan

CVE-2017-5638 adalah celah remote code execution (RCE) pada Jakarta Multipart parser di Apache Struts 2. Parser salah menangani exception dan salah membentuk pesan error saat proses unggah berkas, sehingga penyerang jarak jauh dapat menjalankan perintah sembarang melalui header HTTP yang dimanipulasi, terutama Content-Type [1][2]; varian via Content-Disposition dan Content-Length dilaporkan dalam S2-046 [10]. Versi terdampak adalah Struts 2.3.x sebelum 2.3.32 dan 2.5.x sebelum 2.5.10.1. Celah ini masuk kategori A06 karena akar masalahnya adalah penggunaan komponen pihak ketiga yang rentan dan tidak diperbarui, bukan kesalahan kode buatan sendiri. OWASP sendiri mencantumkan CVE ini sebagai contoh skenario serangan A06 [6].

Studi Kasus

- **Organisasi:** Equifax Inc., biro kredit di Amerika Serikat.
- **Tahun:** 2017 (diumumkan ke publik pada 7 September 2017).
- **Sistem terdampak:** portal sengketa konsumen online (online dispute portal) yang berjalan di atas Apache Struts.
- **Sumber:** NVD [1], Apache Security Bulletin S2-045 [2], laporan GAO-18-559 [3], dan laporan House Oversight Committee (2018) [4].

Kronologi Serangan

1. Awal Maret 2017: Apache merilis patch (Security Bulletin S2-045) [2], dan celah diumumkan secara publik pada 7 Maret 2017 [4].
2. 8 Maret: US-CERT (DHS) mengirim peringatan patch kepada Equifax. Pada 9 Maret, tim Global Threat and Vulnerability Management (GTVM) Equifax meneruskannya lewat email ke sekitar 430 orang dengan tenggat patch 48 jam [4].
3. Aplikasi Automated Consumer Interview System (ACIS) yang menjalankan Struts rentan tidak ditambal. Pemindaian internal pada 15 Maret gagal mendeteksinya, antara lain karena dijalankan pada direktori root, bukan subdirektori tempat Struts berada [4].
4. Menurut GAO, penyerang mulai memindai sistem Equifax dalam dua hari setelah celah diumumkan [3]. Pada 13 Mei 2017, penyerang masuk melalui Struts pada ACIS (portal sengketa konsumen) dan memasang web shell untuk kendali jarak jauh [4].
5. Penyerang menemukan kredensial aplikasi tersimpan tanpa enkripsi, dan karena ACIS tidak tersegmentasi, kredensial itu membuka 48 basis data lain di luar ACIS (total 51 basis data menurut GAO). Sekitar 9.000 kueri dijalankan selama 76 hari tanpa terdeteksi [3][4][8].
6. Deteksi terlambat karena sertifikat SSL pada perangkat pemantau lalu lintas ACIS kedaluwarsa, sehingga lalu lintas terenkripsi tidak terperiksa. Perkiraan lama sertifikat kedaluwarsa berbeda antar sumber: sekitar 10 bulan menurut GAO [3], 19 bulan (kedaluwarsa 31 Januari 2016) menurut dokumen House Oversight [4]. Keduanya berbeda dari 76 hari, yaitu lama penyerang berada di sistem. Setelah sertifikat diperbarui pada 29 Juli 2017, lalu lintas mencurigakan langsung terlihat dan ACIS dimatikan pada 30 Juli [4].
7. 7 September 2017: Equifax mengumumkan insiden kepada publik [4].

Dampak

- **Data terdampak:** nama, tanggal lahir, dan nomor jaminan sosial (SSN); sebagian korban juga terekspos alamat, nomor SIM, dan nomor kartu kredit (Equifax menyebut sekitar 209.000 nomor kartu kredit) [4]. Dua angka berikut tidak sama dan tidak boleh dicampur: (1) sekitar 145,5 juta orang adalah jumlah yang SSN-nya terekspos [3][9]; (2) sekitar 147,9–148 juta adalah estimasi jumlah konsumen terdampak secara keseluruhan, mencakup berbagai jenis data [4][9].
- **Pihak dirugikan:** konsumen sebagai korban langsung, yang berisiko mengalami pencurian identitas dan penipuan keuangan jangka panjang karena SSN sulit diganti; serta Equifax sendiri (kerugian finansial, reputasi, dan pergantian pejabat).

- **Confidentiality (paling rusak):** dampak aktual yang paling jelas: data pribadi sensitif dalam skala sangat besar diakses pihak tidak berwenang.
- **Integrity:** potensi dampak RCE (penyerang dapat mengubah sistem dan data), tetapi tidak terbukti terjadi dalam insiden ini; sumber yang diperiksa tidak melaporkan adanya modifikasi data.
- **Availability:** potensi dampak RCE (penyerang dapat mematikan layanan), tetapi tidak terbukti terjadi; tidak ada laporan gangguan layanan inti akibat serangan ini.

Estimasi Severity

Skor CVSS v3.1	**9,8**
Sumber skor	**NIST NVD, CVSS v3.1 Base Score 9,8 Critical [1]**
Kategori	**Critical**
Vektor	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Alasan: celah dapat dieksploitasi melalui jaringan (AV:N), kompleksitas rendah (AC:L), tanpa autentikasi (PR:N), tanpa interaksi pengguna (UI:N), dan berdampak tinggi pada kerahasiaan, integritas, serta ketersediaan (C:H/I:H/A:H) karena RCE memungkinkan penyerang menjalankan perintah pada server, sehingga berpotensi berdampak tinggi terhadap kerahasiaan, integritas, dan ketersediaan sistem. Skor dan vektor ini mengacu pada penilaian NVD [1], dan CVE ini tercatat dalam katalog Known Exploited Vulnerabilities (KEV) milik CISA [5].

Catatan: skor CVSS menggambarkan potensi dampak teknis kerentanan itu sendiri, bukan ukuran kerugian aktual yang dialami Equifax. Kerugian nyata juga dipengaruhi kegagalan patching, segmentasi yang lemah, dan keterlambatan deteksi. Catatan versi: pada 2017 NVD menilai CVE ini 10,0 (CVSS v3.0, Scope Changed) [4]; penilaian terkini memakai v3.1 dengan Scope Unchanged sehingga 9,8 [1]. Keduanya berkategori Critical. Metrik mengacu pada spesifikasi CVSS [7].

Rekomendasi Mitigasi

1. **Patch management berbasis SLA dan inventarisasi komponen:** perbarui Struts ke 2.3.32, 2.5.10.1, atau versi lebih baru; kelola dependensi dengan inventaris aset/SBOM dan Software Composition Analysis (mis. OWASP Dependency-Check); tetapkan tenggat penambalan untuk kerentanan kritis.
2. **Verifikasi patch secara independen:** peringatan via email tidak cukup, sehingga perlu pemindaian ulang dan pelacakan penyelesaian oleh tim yang berbeda.
3. **Segmentasi jaringan dan least privilege:** pisahkan aplikasi publik dari basis data sensitif, batasi hak akun aplikasi, dan enkripsi data pribadi yang tersimpan (data yang diakses penyerang tidak terenkripsi [4]).
4. **Pemantauan yang andal:** jaga validitas sertifikat pada perangkat inspeksi lalu lintas, pasang WAF, dan buat alarm anomali kueri basis data.
5. **Pengujian keamanan berkala:** lakukan vulnerability scanning dan penetration testing secara berkala setelah patch diterapkan, untuk memastikan patch benar-benar efektif dan tidak ada kerentanan serupa pada komponen lain.

Referensi

[1] NIST NVD. CVE-2017-5638. https://nvd.nist.gov/vuln/detail/CVE-2017-5638

[2] Apache Struts. Security Bulletin S2-045. https://cwiki.apache.org/confluence/display/WW/S2-045

[3] U.S. GAO. (2018). Data Protection: Actions Taken by Equifax and Federal Agencies in Response to the 2017 Breach (GAO-18-559). https://www.gao.gov/products/GAO-18-559

[4] U.S. House Committee on Oversight and Government Reform. (2018). The Equifax Data Breach (Majority Staff Report). https://oversight.house.gov/wp-content/uploads/2018/12/Equifax-Report.pdf

[5] CISA. Known Exploited Vulnerabilities Catalog: CVE-2017-5638. https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2017-5638

[6] OWASP. (2021). A06:2021 – Vulnerable and Outdated Components. https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/

[7] FIRST. Common Vulnerability Scoring System (CVSS). https://www.first.org/cvss/

[8] Fortune/Bloomberg. (2018). Equifax Hack Lasted for 76 Days (sumber sekunder). https://fortune.com/2018/12/10/equifax-hack-lasted-for-76-days-compromised-148-million-people-government-report-says

[9] Threatpost. (2018). "Equi-Facts": Equifax Clarifies the Numbers for Its Massive Breach (sumber sekunder). https://threatpost.com/equi-facts-equifax-clarifies-the-numbers-for-its-massive-breach/131797

[10] Apache Struts. Security Bulletin S2-046. https://cwiki.apache.org/confluence/display/WW/S2-046